



AmeraKey®

# Why PKI Is The Wrong Bet For The Post-Quantum Era?

# Table of Contents

---

**The Problem with PKI is not Just Cost. It is the Model.....3**

**Not All Systems are the Same — and That is the Point.....4**

**The NIST Round 3 Problem: You are Planning Against a Moving Target.....5**

**Closed Systems Fail You Twice: Before the Transition and After.....6**

**AmeraKey: Open, Agile, and Certificate-Free by Design .....7**

    Algorithm Agility Is Not a Feature. It Is the Architecture.....7

    Automated Key Rotation — No Expiration Cliffs.....7

    Audit-Native by Default.....8

**The Financial Case: What Closed Systems Actually Cost.....8**

**The Argument Against Waiting.....9**

**Recommended Next Steps ..... 10**

# PKI Is the Wrong Bet for the Post-Quantum Era

## Why Certificate-Based Trust Infrastructure Fails — and How AmeraKey Eliminates the Problem at the Root

Prepared for: CISOs, Security Architects, and Government IT Leaders

Prepared by: AmeraKey | [security@ameramail.com](mailto:security@ameramail.com) | [www.ameraiot.com](http://www.ameraiot.com)

Reference: NIST IR 8610, May 2026

---

### The Problem with PKI is not Just Cost. It is the Model.

---

*Before we discuss quantum, let us be precise about what PKI is — and what it has always been: a hierarchical trust system built on a single structural assumption that has never aged well. And let us be equally precise about where this critique applies — because not all systems are the same.*

Public Key Infrastructure was engineered for a world of relatively small, stable networks with identifiable authorities at the top. The Certificate Authority was meant to be a trusted anchor. What it became, in practice, is a dependency — a third party whose compromise, misjudgment, or operational failure cascades across every system that trusts it. The 2011 DigiNotar breach did not break one company. It invalidated the trust chain for every certificate that CA had ever signed. That is not an implementation flaw. That is the PKI model working exactly as designed.

*You do not own your trust infrastructure. You rent it — from a vendor, on their terms, at their price, under their uptime guarantee.*

PKI is a closed system by architecture. Every certificate you issue ties your organization to a CA vendor's fee schedule, renewal calendar, revocation infrastructure, and policy choices. When that vendor changes pricing, gets acquired, or suffers an outage, you absorb the consequences. The lifecycle overhead alone — issuance, renewal, tracking, revocation — consumes 1 to 3 full-time employees in a mature enterprise environment. Certificate expiry events are a leading cause of preventable outages, with per-incident costs ranging from **\$5,000 to \$500,000**. This is not a gap that better tooling closes. It is a cost that is inherent to the certificate model itself.

Now add the quantum dimension. Every RSA and ECC certificate in your environment must be reissued when those algorithms are deprecated — not patched, not updated, but replaced end-to-end. For organizations operating complex PKI hierarchies across multiple business units, this is not a single migration. It is a recurring infrastructure rebuild that will need to happen again each time NIST finalizes a new standard. Closed, proprietary PKI implementations make this worse: vendor-specific tooling, siloed management platforms, and bespoke CA configurations multiply migration cost and risk at every step.

*This is not an argument against the existence of Certificate Authorities for public web browsing. CAs serve a legitimate commodity function: establishing trust between strangers on the open internet. That problem is solved. This is an argument against forcing closed, high-security environments — enterprise networks,*

military C2, government intranets, critical infrastructure — to depend on a public trust model that was never designed for them, and that extracts maximum cost and risk precisely where the stakes are highest.

**Core Argument** The quantum transition does not break PKI. PKI was already broken — specifically in the closed, high-security environments where it is most widely deployed and most expensive to operate. The quantum transition simply makes the cost of staying on it impossible to justify.

## Not All Systems are the Same — and That is the Point

*The security landscape is not uniform. The case against PKI is not universal — it is targeted. Understanding the distinction is the foundation of a credible post-quantum strategy.*

| System Type                 | Characteristics                                                                                                                                    | Examples                                                                                                                                                                      | PKI Fit                                                                                                                                                                                       |
|-----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Closed / Controlled Systems | Known, enrolled, credentialed users and nodes. Every identity is established in advance. Trust is pre-arranged, not discovered at runtime.         | Enterprise networks, military C2, government intranets, NATO coalition networks, critical infrastructure (energy, water, finance), healthcare internal systems, B2B platforms | <b>Poor.</b> PKI's CA model imposes third-party dependency, certificate lifecycle overhead, and recurring migration cost on environments that have no need for open-internet trust discovery. |
| Public-Facing Systems       | Anonymous or self-registered users. No prior credential exchange. Trust must be established at connection time between parties who have never met. | Public websites, consumer apps, citizen-facing government portals, e-commerce                                                                                                 | <b>Adequate.</b> PKI's CA model was designed specifically for this: establishing trust between strangers on the open internet. This is a commodity, largely solved problem.                   |

*The world's most sensitive systems — military, government, critical infrastructure — are all closed systems. That is exactly where PKI is most dangerous and most expensive. That is exactly where **AmeraKey** wins.*

**AmeraKey** is purpose-built for closed and controlled environments — the systems that matter most, carry the greatest risk, and bear the highest PKI cost burden. Replacing commodity public TLS is not the mission. Eliminating PKI's stranglehold on high-security, high-value closed environments is. Every section of this document is scoped accordingly.

# The NIST Round 3 Problem: You are Planning Against a Moving Target

*Organizations waiting for final NIST standardization to begin their post-quantum transition are making a calculated bet on a timeline that NIST itself cannot guarantee.*

NIST IR 8610 documents nine digital signature candidates currently advancing through Round 3: **FAEST**, **HAWK**, **MAYO**, **MQOM**, **QR-UOV**, **SDitH**, **SNOVA**, **SQIsign**, and **UOV**. Final standards are not expected before **2028–2030** — and that projection assumes no further eliminations. Five candidates were already removed in Round 2. History suggests more will follow.

The multivariate-based candidates — including UOV and QR-UOV — may require additional analysis cycles before standardization. SQIsign, while mathematically compelling, still lacks a constant-time implementation, making it unsuitable for deployment contexts where timing side-channels matter. These are not minor footnotes. They are signals that the landscape will keep shifting.

**Strategic Risk Organizations** that migrate to ML-DSA today — the right move — will almost certainly need to migrate again when Round 3 candidates finalize. On a PKI-based infrastructure, that second migration carries the same full cost as the first. That is the closed-system trap: you pay to migrate, and then you pay again.

Meanwhile, adversaries are not waiting. **Harvest Now, Decrypt Later (HNDL)** attacks are already in operation. Encrypted data exfiltrated today — protected by RSA-2048 or ECC-256 — will become readable the moment a sufficiently capable quantum computer exists. Every day organizations delay their transition; they are accruing cryptographic debt that cannot be recovered. "Wait for NIST" is not a strategy. It is an exposure.

| NIST Round 3 Candidate | Category         | Status / Notable Risk               | Readiness                    |
|------------------------|------------------|-------------------------------------|------------------------------|
| FAEST                  | Hash-based       | Advancing — analysis ongoing        | Configurable on finalization |
| HAWK                   | Lattice-based    | Advancing — analysis ongoing        | Configurable on finalization |
| MAYO                   | Multivariate     | May require extended review         | Configurable on finalization |
| MQOM                   | Hash-based (MPC) | Advancing — analysis ongoing        | Configurable on finalization |
| QR-UOV                 | Multivariate     | May require extended review         | Configurable on finalization |
| SDitH                  | Hash-based (MPC) | Advancing — analysis ongoing        | Configurable on finalization |
| SNOVA                  | Multivariate     | Advancing — analysis ongoing        | Configurable on finalization |
| SQIsign                | Isogeny-based    | No constant-time implementation yet | Configurable on finalization |
| UOV                    | Multivariate     | May require extended review         | Configurable on finalization |

## Closed Systems Fail You Twice: Before the Transition and After

---

*The full cost of PKI is rarely accounted for correctly. Organizations see certificate fees and licensing. They rarely see the true operational burden — or what that burden becomes post-quantum.*

**Before the quantum transition**, the costs are already significant. CA fees and certificate licenses run **\$50 to \$500 per certificate per year** across enterprise volumes. Certificate operations staff — managing issuance queues, renewal windows, revocation records, and CRL/OCSP infrastructure — consume 1 to 3 FTE. Outage events triggered by expired or misconfigured certificates cost between **\$5,000 and \$500,000 per incident**, with compounding reputational exposure in regulated industries. Manual audit and compliance reporting adds further overhead that scales with certificate volume.

**After the quantum transition**, every one of those costs reappears — multiplied. Every certificate must be reissued with a new post-quantum algorithm. Every validation system must be updated to recognize the new signature format. Root and intermediate CAs must be rebuilt from scratch. For organizations running proprietary PKI stacks, the challenge is compounded by vendor dependency: extracting trust infrastructure from a closed system — if the vendor will cooperate at all — is an expensive, time-consuming, and risk-laden undertaking.

*Organizations that chose proprietary PKI vendors are paying twice — once for the system, and once for the privilege of leaving it.*

The HNDL threat makes this urgency concrete. Data your organization encrypted last year — protected by RSA or ECC — is potentially already in an adversary's possession, waiting for the compute power to decrypt it. Every additional year of operation on classical cryptography without a quantum-safe layer accrues both operational cost and irreversible cryptographic exposure simultaneously.

## AmeraKey: Open, Agile, and Certificate-Free by Design

---

***AmeraKey** was built on a fundamentally different premise: trust does not require a Certificate Authority — at least not in the environments where it matters most. In closed and controlled systems, every user and every node is known before they connect. Cryptographic identity can be established through direct key-pair binding derived from enrolled credentials — no third party, no certificate lifecycle, no vendor dependency.*

Where PKI anchors trust in a CA hierarchy that any enrolled certificate can access, **AmeraKey** anchors trust in the key itself — a key derived from the unique combination of a user-provided image and a PIN. This image+PIN derivation model is designed precisely for environments where users and nodes are *known and enrolled in advance*. That is not a limitation. It is the security property. Pre-enrollment means cryptographic identity is tightly controlled, fully auditable, and entirely independent of any third-party CA. Each authorized user or node holds a distinct image+PIN credential pair that cannot be transferred, spoofed, or obtained without both factors. PKI's open trust model — appropriate for public strangers on the internet — is unnecessarily risky and structurally expensive when applied to controlled environments where every identity is already known. **AmeraKey** eliminates that mismatch. Identity for users, machines, workloads, containers, and AI agents is established and managed through a unified control plane

accessible via open API and CLI interfaces. There is no proprietary black box. There is no vendor whose cooperation you need to migrate, rotate, or revoke credentials.

**Algorithm Agility Is Not a Feature. It Is the Architecture.**

**AmeraKey** adopts finalized NIST PQC standards — **ML-DSA** and **SLH-DSA** — now, without waiting for the full Round 3 landscape to settle. When any of the nine current candidates finalize, organizations on **AmeraKey** adopt them through a **configuration change** — not a re-architecture, not a re-issuance campaign, not a migration project. The algorithm layer is abstracted from the identity layer by design. This is what algorithm agility actually means: not the ability to migrate, but the ability to transition without migration cost.

**Automated Key Rotation — No Expiration Cliffs**

Keys in **AmeraKey** rotate on a schedule defined by the organization, executed via API, with no expiration windows, no renewal queues, and no outage risk. The operational model that makes certificate expiry a recurring crisis simply does not exist in a certificate-free architecture.

**Audit-Native by Default**

Every key event — issuance, rotation, revocation, access — is recorded in a tamper-evident ledger in real time. There is no separate log aggregation pipeline. There is no siloed reporting system. Compliance evidence is a native output of the platform, not a retrospective reconstruction exercise.

| Capability               | Traditional PKI                          | AmeraKey                                          |
|--------------------------|------------------------------------------|---------------------------------------------------|
| Trust anchor             | Certificate Authority (third party)      | Direct key-pair binding (no CA)                   |
| Algorithm transition     | Full re-issuance campaign                | Configuration change                              |
| Key/certificate rotation | Manual renewal windows, expiry risk      | Automated via API, no expiration cliff            |
| Vendor dependency        | CA vendor, fee schedule, uptime SLA      | None — open API/CLI                               |
| Audit & compliance       | Manual log aggregation, siloed reporting | Native tamper-evident key event ledger            |
| Identity scope           | Users and servers (limited)              | Users, machines, workloads, containers, AI agents |
| PQC standards supported  | Requires full infrastructure rebuild     | ML-DSA, SLH-DSA now; Round 3 on finalization      |

# The Financial Case: What Closed Systems Actually Cost

The cost argument for **AmeraKey** is not marginal — and it is most acute in exactly the environments **AmeraKey** targets: enterprise, government, and defense closed-system PKI deployments where certificate volumes are highest, CA dependencies are deepest, and migration costs are most severe. For a 5,000-certificate enterprise on traditional PKI, the five-year total cost of ownership typically falls between \$1.5M and \$3M — before quantum migration costs are added. Public-facing TLS certificate costs, by contrast, *\*\*are* largely commoditized and outside the scope of this comparison.

| Cost Category                | Traditional PKI                                   | AmeraKey                               | Reduction               |
|------------------------------|---------------------------------------------------|----------------------------------------|-------------------------|
| CA & certificate fees        | \$50–\$500 per cert/year × enterprise volume      | Flat platform subscription             | 60–80%                  |
| Certificate operations staff | 1–3 FTE dedicated                                 | Automated via API                      | 80–90% time reduction   |
| Outage / incident response   | \$5K–\$500K per certificate expiry event          | Near elimination (no expiration model) | Near 100%               |
| PQC migration                | Full re-issuance across all endpoints — recurring | Algorithm swap via configuration       | 70–85%                  |
| Audit & compliance           | Manual log aggregation, third-party tooling       | Native key event ledger                | 50–70% effort reduction |
| Third-party CA dependency    | Vendor lock-in, extraction costs                  | None                                   | Full control restored   |

**Total Cost Comparison — Closed/Enterprise/Government PKI Deployments** A 5,000-certificate enterprise or government closed-system PKI deployment typically spends \$1.5M–\$3M over five years in direct and operational costs. **AmeraKey** delivers a 60–75% total cost reduction in that window — with the gap widening materially when post-quantum migration costs are factored in. The second PKI migration, inevitable for any organization that transitions to ML-DSA today and must transition again when Round 3 candidates finalize, is where the math becomes decisive.

## The Argument Against Waiting

"Wait and see" has three specific failure modes that security leaders should be able to articulate to their boards.

**1. HNDL attacks are not theoretical — they are in progress.** Adversaries with access to sufficient storage are exfiltrating encrypted data now, with the explicit intent to decrypt it once quantum compute matures. Every day your most sensitive data transits a network protected only by RSA or ECC, it is a candidate for harvest. Waiting for NIST does not stop this clock.

**2. PKI migrations take longer than organizations expect.** Organizations that plan to begin their post-quantum PKI migration in 2028 — when NIST finalizes Round 3 — will find themselves executing a complex, multi-phase infrastructure project against an accelerating threat timeline. The organizations that complete quantum-safe transitions first are the ones that started building the model now — not the ones that waited for a complete standard set.

**3. Every year of PKI operation is a year of avoidable cost.** Certificate fees, renewal labor, and outage exposure continue to accrue regardless of the quantum timeline. Delaying the transition to [AmeraKey](#) does not defer cost — it extends it.

*The strategic bet is not on a specific algorithm. It is on a model. Certificate-free, algorithm-agile infrastructure outperforms traditional PKI regardless of which NIST candidates standardize — and delivers savings from day one.*

Algorithm agility is the correct frame. Organizations do not need to know which Round 3 candidate will win. They need infrastructure that can adopt any finalist without rebuilding. [AmeraKey](#) provides that today. PKI cannot provide it — ever — without complete re-architecture.

## Recommended Next Steps

*The transition from certificate-based infrastructure to a certificate-free, algorithm-agile model begins with a clear understanding of scope — specifically, which of your systems are closed and controlled ([AmeraKey](#) candidates) and which are public-facing (outside [AmeraKey](#)'s scope). The following five-phase structure is designed to deliver measurable value at each step, starting with that scoping exercise.*

| Phase                                    | Timeline  | Activity                                                                                                                                                                                                                                                                                                 | Outcome                                                                                         |
|------------------------------------------|-----------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|
| <b>Phase 0</b> Scope Assessment          | Days 1–5  | Identify and classify systems as closed/controlled (known, enrolled users and nodes — <a href="#">AmeraKey</a> candidates) vs. public-facing (anonymous users, commodity TLS — outside <a href="#">AmeraKey</a> scope). Prioritize by certificate volume, quantum exposure, and operational cost burden. | Precisely scoped pilot target; no resources spent outside high-value closed-system environments |
| <b>Phase 1</b> Crypto Posture Assessment | Weeks 1–2 | Map current certificate inventory, CA dependencies, algorithm exposure, and key management gaps across scoped closed/controlled                                                                                                                                                                          | Full visibility into PKI cost burden and quantum exposure profile within targeted environments  |

| Phase                                    | Timeline    | Activity                                                                                                                                                                                      | Outcome                                                                                                    |
|------------------------------------------|-------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|
|                                          |             | systems. No agents required.                                                                                                                                                                  |                                                                                                            |
| <b>Phase 2</b> <b>AmeraKey</b> Pilot     | Weeks 3–8   | Bounded deployment within a defined closed/controlled system segment to validate the certificate-free, image+PIN key derivation model. Measure operational savings directly against baseline. | Quantified ROI, validated architecture, stakeholder confidence                                             |
| <b>Phase 3</b> Phased PKI Replacement    | Months 3–12 | Replace certificate-based authentication systematically across closed/controlled environments, beginning with highest PKI cost centers and greatest quantum exposure.                         | Progressive elimination of CA dependency in targeted environments; FTE redeployment; outage risk reduction |
| <b>Phase 4</b> Ongoing Algorithm Agility | Continuous  | Adopt future NIST standards as finalized via configuration — no migration projects, no re-issuance campaigns.                                                                                 | Permanent immunity to algorithm deprecation cycles; zero recurring migration cost                          |

**Starting Point** The Phase 0 Scope Assessment is a fast, no-commitment exercise that identifies precisely which of your systems are closed/controlled **AmeraKey** candidates — so every subsequent phase is targeted and efficient. The Phase 1 Crypto Posture Assessment that follows requires no agents, no infrastructure changes, and no vendor commitments. Together they produce a precise picture of your PKI cost structure, quantum exposure, and deployment opportunity within your highest-value environments. Contact [security@ameramail.com](mailto:security@ameramail.com) to schedule.

**AmeraKey** | [security@ameramail.com](mailto:security@ameramail.com) | [www.ameraiot.com](http://www.ameraiot.com)

This position paper was prepared in response to NIST IR 8610, May 2026.

© 2026 **AmeraKey**. All rights reserved. The financial estimates, cost ranges, and projections contained herein are derived from aggregated enterprise deployment data and publicly available PKI operational benchmarks. Actual savings will vary by organization size, certificate volume, and existing infrastructure complexity.